

Docker Security

Rootless · Seccomp · Capabilities · Image Scanning

■ Analogy

- Container security is like a bank vault with multiple locks. Namespaces are the vault walls (isolation). Capabilities are individual keys — you only hand out keys needed for the job. Seccomp is a guard who blocks unusual requests. Running as root is like giving every employee a master key — dangerous.

Key Terms

Rootless Docker	Run dockerd and containers as non-root user — eliminates host privilege escalation risk
USER instruction	Switches to non-root user inside container. Critical for production images
Linux Capabilities	Fine-grained root privileges. Drop ALL, add only what's needed (e.g., NET_BIND_SERVICE)
Seccomp	Syscall filter — blocks dangerous system calls. Docker's default profile blocks ~40 syscalls
AppArmor / SELinux	Mandatory access control profiles that restrict what a container process can do on the host
--read-only	Mount container's root filesystem as read-only — prevents tampering at runtime
--no-new-privileges	Prevents processes from gaining extra privileges via setuid/setgid
Image scanning	Static analysis of image layers for known CVEs — Trivy, Snyk, Docker Scout
Content Trust	Docker image signing (Notary) — ensures pulled image matches publisher's signed version
Secrets	docker secret / --secret — inject sensitive data without env vars baked into images

Security Hardening Checklist

Control	How To Apply	Risk Mitigated
Non-root user	USER appuser in Dockerfile	Host privilege escalation
Drop capabilities	--cap-drop=ALL --cap-add=NET_BIND_SERVICE	Kernel exploit surface
Read-only FS	docker run --read-only	Malware persistence
No new privileges	--security-opt no-new-privileges	setuid escalation
Resource limits	--memory=512m --cpus=0.5	DoS / noisy neighbor

Image scanning	trivy image myapp:latest	Known CVEs
Distroless base	FROM gcr.io/distroless/java17	No shell attack surface
Network policy	User-defined bridge + firewall rules	Lateral movement

Scan image with Trivy + Secure run flags

```
# Install Trivy (CVE scanner)
brew install trivy # or apt-get install trivy

# Scan image for HIGH/CRITICAL vulnerabilities
trivy image --severity HIGH,CRITICAL myapp:latest

# Run with security hardening flags
docker run -d \
  --name app \
  --read-only \
  --no-new-privileges \
  --cap-drop=ALL \
  --cap-add=NET_BIND_SERVICE \
  --memory=512m --cpus=0.5 \
  --security-opt seccomp=/etc/docker/seccomp.json \
  --security-opt apparmor=docker-default \
  --tmpfs /tmp \
  myapp:latest
```

■ Real-World: Capital One

- After a 2019 S3 misconfiguration breach, Capital One overhauled container security: all Docker images run as non-root, capabilities are dropped to minimum, Trivy scans are gated in CI/CD pipelines, and containers run with --read-only. They published their approach as an open-source policy-as-code framework.